qaZAR: Developer Audit and Remediation Specification

27 October 2026 | Prepared for the tool’s developer
Target: https://courage-1984.github.io/qaZAR/index.html
Purpose: prevent misleading website assessments and replace unsupported rebuild recommendations with reproducible findings.

1. Executive assessment

The supplied Logia and Logi-Ink reports materially overstate what their measurements establish. The current source converts heuristic observations into severe grades, automatic rebuild advice and formula-derived engineering estimates. This is a reporting-integrity defect, independently of whether individual website defects are real.
The tool can remain useful as a viewport inspection assistant. Its public-facing conclusions should be suspended or relabelled until scoring, evidence handling and uncertainty are corrected. Do not resolve this by simply raising scores: remove unsupported conclusions and validate each rule.
Both homepages returned HTTP 200 during this investigation. Exa retrieved their content and Tavily retrieved internal pages. This is availability evidence, not proof that every interaction works or that either website meets accessibility requirements.

2. Scope, evidence and limitations

Reviewed: both five-page reports supplied by the owner; current public scoreCalculator.js, reportGenerator.js, capturePage.js and heuristics/evaluate.js; the public frontend; W3C target-size guidance retrieved through Tavily; prior qaZAR audit records in Google Drive.
This is a source and report audit, not a penetration test, complete browser interaction audit or certification. No repository changes, live audit jobs, form submissions or destructive tests were performed. Current main-branch source was retrieved without an immutable commit pin; it may differ from the deployed engine that produced the PDFs. Findings explicitly distinguish current code behaviour from observed report output. A developer must capture the deployed commit and original run JSON before reproducing historical results.
Previous Drive security findings are historical leads, not automatically current vulnerabilities. The earlier audit expressly excluded the scoring module; this review inspects that module directly.

3. Case-study evidence

Logia: 9 pages, 7 viewports, F / 15, 44 error clusters, 507 raw errors, 20 recurring clusters, 458 touch observations, 666 contrast-category observations, one overflow observation, 90 estimated hours.
Logi-Ink: 29 pages, 7 viewports, F / 15, 55 error clusters, 2,311 raw errors, 53 recurring clusters, 2,672 touch observations, 1,438 contrast-category observations, 290 estimated hours.
Both reports show search appearance 100/100 and transport protection 100/100. These are separate dimensions and do not mathematically contradict poor UX, but the overall presentation hides that distinction.
Category totals need not equal raw errors: current code sums occurrences irrespective of severity. In particular, informational contrast-indeterminate observations match the substring 'contrast' and enter the contrast category. The PDF cannot establish how many category observations were confirmed failures without the raw run data.

4. P0 — Scoring collapses into a meaningless floor

Evidence: calculateHealthScore deducts 6 points per error cluster and 2.5 per warning cluster, plus up to 10 points for duplicate errors, 5 for duplicate warnings and 2 per changed baseline count. It clamps the result to 15–100. Fourteen error clusters plus some additional penalties can reach the floor; either supplied report's error count exceeds the available scale by itself.
Impact: very different sites receive the same score; larger sites accumulate more opportunities for deductions. Visual changes also reduce health even when they are intentional improvements. Availability, successful tasks and measured business outcomes do not enter this formula.
Fix: remove the overall grade initially. Publish separate functional, accessibility, layout and performance findings with tested coverage. If a score returns, define eligible checks and denominators, exclude unknown results, publish weights and calibrate against independently reviewed fixtures. Score unique causes separately from prevalence. A baseline change should be a review signal, not automatically a defect.
Acceptance: repeating identical templates across 100 URLs must not multiply a single repair into 100 independent defects. An intentional approved visual change must not worsen health. Incomplete scans must never receive an unqualified grade.

5. P0 — Rebuild advice and estimates are automatic

Evidence: estimateRemediationRoi chooses rebuild when score <65 OR globalDefects >=3 OR legacy debt with score <75. Its reason alleges legacy frameworks even when hasLegacyDebt is false. Rebuild effort is Math.max(25, totalPages * 10). This reproduces 90 and 290 hours exactly.

Impact: three repeated CSS findings can trigger a complete rebuild. The estimate measures page count, not engineering work. Neither implementation cost nor economic ROI is calculated.
Fix: remove automatic rebuild advice, claims of superior ROI and page-count estimates. Present verified component fixes first. Rebuild advice requires a human architecture review, documented alternatives, dependencies and a scoped estimate range with assumptions. WordPress detection alone is not evidence of obsolete architecture.
Acceptance: three shared minor issues cannot generate rebuild advice. No estimate is displayed without a documented work breakdown and responsible reviewer. No legacy-framework claim appears without identified evidence.

6. P0 — Unknown results become failures or passes

Evidence: category aggregation includes any rule containing 'contrast', including wcag-contrast-indeterminate. generateActionRoadmap then says all these observations require colour adjustments. reportGenerator uses security?.score || 100, which turns a genuine numeric zero into 100. Missing flags can become 'Transport Protected'; absent asset metrics can become positive async/defer and compression labels. A missing robots value is treated as present unless explicitly false. Missing social metadata structures can produce missing-tag warnings.
Impact: both false alarm and false reassurance are possible. The reports' 100/100 security labels cannot be accepted as verified security assessments from their appearance alone.
Fix: require explicit states: pass, fail, needs-review, not-tested, error and not-applicable. Use null checks rather than truthiness for numeric values. Render unknown as unknown; never manufacture a pass or failure from missing data. Count confirmed and indeterminate contrast separately.
Acceptance: security score 0 remains 0; missing security data displays Not tested. An image-background contrast check displays Needs review and causes no failure penalty. Missing metadata collection cannot claim tags are absent.

7. P0 — Touch-target rule misstates accessibility requirements

Evidence: evaluate.js flags width <48 OR height <48; most are errors and inline links become warnings. The roadmap describes 48×48 as an accessibility minimum. W3C WCAG 2.2 SC 2.5.8 AA uses 24×24 CSS pixels with exceptions; SC 2.5.5 AAA uses 44×44 with exceptions.
Fix: implement named standards separately from optional design recommendations. Evaluate actual clickable area, spacing exceptions, inline-context exceptions, equivalent controls and applicability. Do not claim all inline links fail. Apply relevant criteria across pointer input modes rather than equating accessibility solely with a touch-emulated viewport.

Acceptance: rectangular 44×44 and 40×40 controls pass AA size checks. A 24×24 eligible target passes. A smaller target with qualifying spacing is not automatically failed. Optional 48px comfort advice is labelled advisory and cannot trigger critical status or rebuilding.

8. P1 — Contrast evaluation can misidentify rendered colours

Evidence: getEffectiveBg walks from child to ancestor but composites each new ancestor over the accumulated child colour, reversing layering for translucent backgrounds. Foreground alpha is parsed but not composited against the background before luminance calculation. Candidates use innerText, so container text can be evaluated using a parent's colour even when children paint differently. Visibility is based on the element's own style and dimensions; clipping, ancestor opacity and occlusion are not comprehensively resolved. Pseudo-elements and complex paint layers are not modelled. The current code does correctly mark detected background images/gradients as indeterminate, but report aggregation then mishandles those results.
Impact: reported white-on-white headings and logo-link contrast may be false positives; they remain unconfirmed until the specific rendered state is inspected. Do not assert all contrast failures are false.
Fix: use a maintained accessibility engine for supported cases, retain its incomplete results, and manually assess unsupported paint combinations. Measure actual text runs; composite layers in correct order and account for alpha. Capture evidence screenshots and computed styles. Pin and record engine versions.
Acceptance fixtures: translucent text; nested translucent backgrounds; gradient and image backgrounds; pseudo-element overlays; inherited child colours; hidden ancestors; logo-only links; genuine low contrast; large-text thresholds. Every confirmed failure must reproduce at the captured state.

9. P1 — Media and layout heuristics confuse intended design with breakage

Evidence: media-bleed flags any media whose right edge exceeds viewportWidth, without the ancestor clipping checks used in the separate overflow-offender rule. Logi-Ink's PDF identifies images inside blog-related carousel structures. Off-screen carousel items can therefore trigger errors even when correctly clipped. The rule checks the right edge but does not symmetrically establish left-edge breakage.
Collision checks compare bounding boxes for up to 60 elements, skip ancestor pairs and all fixed-position pairs, but do not establish meaningful occlusion or blocked interaction. Navigation checks find any matching toggle in the whole document; they do not verify the relevant menu opens or remains keyboard accessible.

Fix: model clipping and scroll containers consistently. Distinguish document overflow, intentional component scrolling and inaccessible clipped content. Require visual or interaction evidence for a blocker. Test navigation state transitions, focus, keyboard operation and menu association. A hamburger is not intrinsically required for responsive navigation.
Acceptance: clipped carousel passes; genuinely overflowing article image fails; deliberate overlapping decorative layers are not blockers; an overlay blocking a CTA is detected; an unrelated toggle cannot make broken navigation pass.

10. P1 — Counts, clustering and coverage are misleading

Evidence: clusterDefects removes nth-of-type segments and groups by rule plus normalized selector. It retains the first severity and detail, potentially conflating different instances. A finding on two pages qualifies as global. The report translates recurring clusters into shared components, although a selector cluster is not a verified component. Only eight clusters are printed. evaluate.js caps stored observations at 50 per rule, checks up to 60 contrast candidates and samples 60 collision elements. Dropped counts are not returned as explicit coverage. totalCaptures is pages ×7 rather than a successful-capture count.
Fix: distinguish observations, affected nodes, affected pages, root-cause groups and verified reusable components. Preserve per-instance severity and evidence. Label 'observed on 2 of 29 pages' rather than site-wide. Expose all findings through an appendix or export. Report attempted, completed, failed and skipped captures and all sampling limits. Do not call capped observations exhaustive totals.
Acceptance: mixed severities cannot depend on traversal order; different links are not silently merged as one verified root cause; counts reconcile across summary and appendix; failed viewports reduce coverage; reaching a sampling cap produces a visible warning.

11. P1 — Capture modifications can change what is being audited

Evidence: capturePage.js replaces Date with a fixed 1 January 2024 value, replaces Math.random, disables animations/transitions, tolerates a 3-second network-idle timeout, auto-scrolls with a 2.5-second budget and 20,000px stopping threshold, then waits 250ms after font readiness handling.
Impact: date-sensitive widgets, animation-driven visibility, lazy loading and asynchronous content can be captured in artificial or incomplete states. These are risk mechanisms identified from code, not proof that every supplied finding arose this way.
Fix: separate deterministic visual-regression mode from production-behaviour auditing. Record all injected modifications. Use bounded readiness criteria for fonts, image decoding and relevant

application signals. Capture before/after evidence when freezing animation changes visibility. Mark timeout/partial coverage explicitly. Preserve real time in functional audits unless a fixture deliberately requires a clock.
Acceptance: animation-revealed text is visible before checking; delayed components produce either verified readiness or an incomplete result; production-time and deterministic modes are distinguishable in exports.

12. P1 — Business, legal and ownership claims exceed evidence

Evidence: reportGenerator inserts the same 'up to 28%' checkout conversion-loss statement whenever touch observations exist. Mobile risk becomes High for any touch or overflow count. The report presents ADA/EAA exposure without analysing jurisdiction or applicability. Contact scraping is labelled Verified Domain Ownership; the Logi-Ink report includes a regulator’s complaint address among contacts. These are not ownership verification results.
Fix: remove unsupported numerical loss claims and legal conclusions. State measured user impact only when supported by analytics or a controlled test. Use precise language such as 'small target may be difficult to activate'. Rename contacts to Publicly listed contacts and distinguish first-party, third-party and legal/regulatory addresses. Keep commercial quote prompts separate from technical findings.
Acceptance: no revenue percentage, legal-liability conclusion or verified-owner badge is generated by these heuristics. A privacy-policy regulator address is never designated a business lead.

13. Additional validation and operational safeguards

SEO and infrastructure: distinguish static-response metadata from rendered DOM metadata. Store exact tag evidence and tested URL; report canonical and Open Graph coverage per page. A 0ms latency value requires provenance and timing precision; absent measurements should be unknown. HTTPS/header checks must be labelled transport/header checks, not a comprehensive security score. Detecting a form does not verify delivery, validation or spam protection. Do not submit live enquiries without authorization.
Security follow-up: the Drive audit dated 25 October reported unauthenticated API access, permissive CORS, SSRF concerns, report XSS and process-killing behaviour. The 26 October update described live unauthenticated run listing. Revalidate against the deployed commit before treating these as current. Current capturePage does call assertPublicUrl after navigation; that is not equivalent to preventing private-network redirects or subresource requests before they occur. Review request interception, network isolation, authentication, authorization, rate limits and artifact retention. No exploitation was attempted here.

The present audit does not establish dependency vulnerability status, penetration resistance, complete crawl correctness or real-user performance. Schedule those as separate test workstreams.

14. Proposed finding and report contract

Each finding should include: stable ID; rule and engine version; standard and criterion or explicit advisory classification; result state; severity; confidence; URL and final URL; viewport, browser and input mode; timestamp; selector and component hypothesis; observed and expected values; screenshot/evidence reference; reproduction steps; affected-page denominator; root-cause grouping status; remediation; verification result.

Run-level metadata should include commit SHA, configuration, exclusions, requested and successful captures, failures, sample caps, timeouts, injected browser modifications and coverage by category.

Suggested report order: scope and completion; verified functional failures; confirmed standards failures; advisory improvements; needs-review findings; passed checks; evidence appendix.

Business impact should describe the specific blocked task, not an invented financial loss. No single grade is preferable to an uncalibrated grade.

15. Regression suite and release acceptance

Build deterministic fixtures for every failure mechanism above and compare with independent manual review. Include clean simple pages, long sites sharing a footer, deliberately broken navigation, true overflow, clipped carousels, disabled controls, nested text colours, gradients, missing measurements and interrupted captures.

Mandatory release gates:

1. All defined pass fixtures remain free of critical failures.
2. Deliberately broken interactions are reproduced with evidence.
3. Unknown and incomplete states never become passes or failures.
4. Category totals reconcile with exported records and severity.
5. Duplication changes prevalence but not the number of unique verified repairs.
6. Advisory findings cannot trigger rebuild or financial estimates.
7. Each PDF exposes the same findings and coverage as the underlying JSON.
8. A manually reviewed sample of real sites is used to measure false-positive and false-negative rates before publishing scoring claims.

Re-run Logia and Logi-Ink after fixes and publish a before/after reconciliation: retained findings, withdrawn findings, needs-review findings and reasons. Do not promise a specific replacement score or declare both sites defect-free.

16. Implementation sequence

P0 release: remove rebuild/ROI/hour automation; correct target-size labelling; separate unknowns; repair zero-score defaults; exclude indeterminate contrast from failures; disclose coverage; remove unsupported commercial and legal claims.
P1 engine release: correct contrast layering and candidate selection; clipping-aware media checks; meaningful visibility and interaction checks; separate production and deterministic capture modes; evidence-rich schema and complete export.
P2 calibration release: independently reviewed fixtures and live-site sample; measured precision/recall by rule; documented versioned scoring only if justified; migration and correction notice for historical reports.
Assign an accountable engineering owner and reviewer per change. Estimate effort after code-level scoping, not from the number of audited website pages. Version every change affecting results so old and new runs remain interpretable.

17. Source register

Current code retrieved 27 October 2026:
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/report/scoreCalculator.js
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/report/reportGenerator.js
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/heuristics/evaluate.js
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/engine/capturePage.js
https://courage-1984.github.io/qaZAR/index.html
Standards retrieved through Tavily:
https://www.w3.org/WAI/WCAG22/Understanding/target-size-minimum.html
https://www.w3.org/WAI/WCAG22/Understanding/target-size-enhanced.html
Historical project records, used only with date qualifications:
https://docs.google.com/document/d/10HvEBEQylKk3tR3hvyqXqayLjYS_fAEXxDOuszONEzY/edit
https://docs.google.com/document/d/123I5s4qBmszci1zQ1fnzReGK52kMfB4WVNdfoSePXmA/edit
Owner-supplied evidence: qaZAR Executive Audit – https___logia.co.za_.pdf (27 October, 14:50 print header, run 20261027124857-b0f91b); qaZAR Executive Audit – https___logi-ink.co.za_.pdf (27 October, 15:00 print header, run 20261027125138-d83a53).
Print-header timezone not independently established.
Skill-creator guidance was consulted as requested. This deliverable is a developer audit specification; no personal skill was installed or modified.

18. Cross-review reconciliation: Claude, GPT5.5 and Grok

Added after reviewing the three owner-supplied transcripts against public source. Agreement between these reviews is not independent corroboration: all three include the same earlier explanation as input. Claims are accepted on source evidence, not model votes.

New verified finding — repository instructions reproduce the standard error
.agents/rules/heuristics.md describes errors as objective standard violations and includes "<48px target"; it prescribes a 48×48 touch threshold. Correct this file with the evaluator, README and relevant agent prompts. Otherwise later maintenance can reintroduce the same misclassification. These repository instructions were treated as audit evidence, not instructions for conducting this review.
Acceptance: documentation and executable rules agree on AA 24px, AAA 44px and optional 48px guidance, with applicable exceptions.

New verified finding — tests preserve misleading outputs
server/test/unit.test.js explicitly expects a repeated two-page navigation finding to be global and to generate strategic roadmap content. A report test requires "Verified Domain Ownership & Key Contacts" and the rebuild-assessment section. These assertions must change with the product contract. Retain regression coverage, but assert truthful labels, provenance and uncertainty rather than preserve legacy wording. This review did not run the test suite or prove that no additional tests exist elsewhere.

New verified finding — discovery routes start with unmeasured defaults
crawl.js returns emptyProfile() for explicit-page and sitemap discovery. That object initializes latency to 0, security to 100 with isHttps true, asset counts to zero, favicon to true and social tags to false. BFS instead collects timed HTTP responses and aggregates signals. This confirms a route-dependent provenance problem at queue construction.
Qualification: jobQueue.js subsequently calls absorbRendered() for desktop HTML; other enrichment can change the final profile. Therefore queue defaults alone do not prove which values survived into either historical PDF. Trace absorb.js, finishRun.js and the actual saved run JSON before assigning a complete causal chain.
Fix: initialize unmeasured fields as unknown and track provenance per field. Test all three discovery routes against the same site and require equivalent measured results or explicitly different coverage. Do not globally reject every numeric 0ms: rounding can produce zero; absence must be represented separately from a valid measurement.

New verified finding — typography preferences enter the score
evaluate.js treats body font below 16px as an error. jobQueue.js flags unchanged or larger mobile headings and treats H1 size at or below body text size as an error. These conditions alone establish neither broken layout nor a cited accessibility failure. Convert them to optional design-review observations unless measurable clipping, readability or standards evidence supports a stronger finding.
Acceptance: a legible, semantically correct design with intentionally constant heading sizes cannot receive an objective failure solely for that choice.

Corrections to proposed fixes in the supplied reviews

- Do not suppress all 1.00:1 contrast results. Identical foreground and background colours can be a genuine failure. Mark uncertainty only when the measurement is unreliable.
- Do not categorically forbid a white background fallback. The actual canvas can be white. Resolve the painted background or return unknown when unsupported layers prevent a sound determination.
- Screenshot pixel sampling or elementsFromPoint at one position is not a complete contrast oracle. Anti-aliasing, glyph pixels, overlays and spatially varying backgrounds require careful handling and manual review where necessary.
- A rectangular 44×44 control can satisfy the target-size dimension of AAA; this does not certify the control or website as AAA compliant.
- The 50% and 70% “site-wide” thresholds suggested by different reviews are proposed policies, not standards. Prefer explicit affected/tested counts and distinguish recurring findings from verified shared components.
- Removing the score floor alone leaves excessive deductions and false positives intact. A negative raw score would not make the assessment more meaningful. Withdraw or calibrate the score.
- One normalized selector is not necessarily one repair. Root-cause grouping needs validation; selector collisions and different page implementations must remain distinguishable.
- Do not require page-level horizontal scrolling for every layout failure. Clipped essential content or an unusable component may be defective without document overflow. Conversely, intentional carousel scrolling is not a defect.
- Grok’s statement that a one-page run can be global conflicts with the quoted code’s totalPages > 1 condition. One-page runs are excluded.
- Grok’s statement that horizontal overflow did not appear in either report conflicts with Logia’s PDF, which lists one layout/horizontal-breakage observation.
- Grok’s claim that 100/100 search/security and an F UX grade cannot coexist is incorrect: they describe different categories. Their measurement validity must be assessed independently.
- Gradients on walked ancestors are already detected by the current contrast code and classified indeterminate. Do not report that capability as wholly absent; sibling paint layers and pseudo-elements remain distinct limitations.
- Claude’s specific explanation of Logia’s sibling background and its live metadata claims remain hypotheses in this consolidated audit until the relevant deployed HTML/CSS and run evidence are captured.
- The temporary-tunnel 530 reported in GPT5.5 is a time-specific observation from that transcript, not a current outage verified here.
- Neither functional blockers, deprecated markup nor an outdated stack automatically justifies rebuilding. Human review must compare targeted repairs with replacement.
- Filtering contacts solely to the audited domain would discard legitimate external business mailboxes. Classify source and role, retaining uncertainty.
- Do not mandate a C-or-better score for these sites before measuring them. Acceptance should test correct findings and truthful reporting, not force a favourable result.

Additional source references

https://raw.githubusercontent.com/Courage-1984/qaZAR/main/.agents/rules/heuristics.md
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/test/unit.test.js
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/crawler/crawl.js
https://raw.githubusercontent.com/Courage-1984/qaZAR/main/server/queue/jobQueue.js
Submitted comparison material: Claude.txt, GPT5.5.txt and Grok.txt. These are review claims, not substitutes for primary evidence.